INF1416
Segurança da Informação

Prof. Anderson Oliveira da Silva
D. Sc. Ciências em Informática
Engenheiro de Computação
anderson@inf.puc-rio.br

Departamento de Informática
PUC-Rio

DEPARTAMENTO DE INFORMÁTICA PUC·RIO

PUC RIO

Ementa

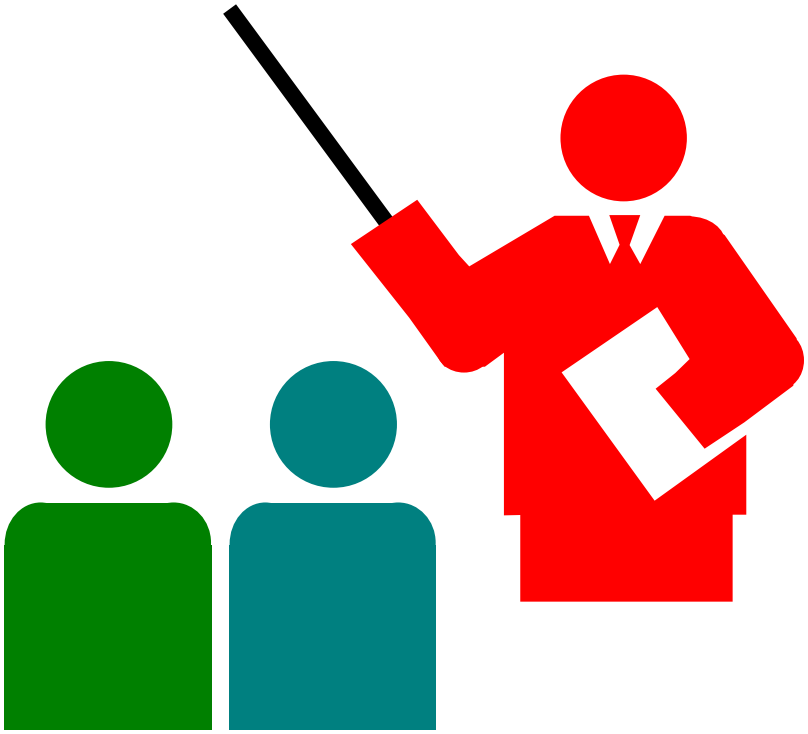
- Segurança da Informação
  Prof. Anderson O. da Silva

Normas e Padronização:

- Principais Normas de Segurança
- Certificação de Segurança da Informação
- NBR ISO/IEC 27001:2006
  - Processo de Certificação
  - Processo de Implantação
- NBR ISO/IEC 27002:2013
  - Objetivos de Controles
  - Controles

Normas e Padronização

- Segurança da Informação
  Prof. Anderson O. da Silva



Normas e Padronização

Norma é aquilo que se estabelece como base ou medida para a realização de alguma coisa. A padronização é uma referência de qualidade.

- **A atividade de normalização estabelece, em relação a problemas existentes ou potenciais, prescrições destinadas à utilização comum e repetitiva com vistas à obtenção do grau ótimo de ordem em um dado contexto.**



Principais Normas de TI e Segurança

Orange Book (Livro Laranja) – ano 1983.

- Publicado nos Estados Unidos.
- Proposta do Departamento de Defesa que definia *critérios para classificação das informações e da segurança das informações*.
- Apesar de ter sido escrito para os órgãos do governo dos EUA, tornou-se um padrão comercial de uso geral.
- Previa o estabelecimento de uma política de segurança, além de controles de gerenciamento das informações.



Principais Normas de TI e Segurança

ITIL - Information Technology Infrastructure Library

- ano 1989.

- Criado pelo governo britânico.
- Trata-se de um *conjunto de orientações* desenvolvido pelo Office of Government of Commerce (OGC), órgão do governo britânico.
- Descreve um *modelo de processo integrado de melhores práticas para prover a qualidade de serviços de TI*.
- Este modelo foi lançado na América do Norte em 1996.

ITIL® IT Service Management Best Practice

OGC Office of Government Commerce

Principais Normas de TI e Segurança

CobiT - Control Objectives for Information and Related

Technology – ano 1996.

- **Primeira edição publicada pela ISACA (Information System Audit and Control Foundation).**
- **Conjunto de *práticas que visam auxiliar a gestão e controle de iniciativas de TI* nas empresas reduzindo os riscos correspondentes.**
- **Atualmente encontra-se na sua quarta edição, publicada em 2005.**
- **O tema principal do CobiT é a *orientação aos negócios*.**



Principais Normas de TI e Segurança

NIST Série 800 – início em 1995.

- Publicado pelo NIST - National Institute of Standards and Technology - U.S. Department of Commerce.
- A pioneira foi a SP800-12 An Introduction to Computer Security: The NIST Handbook, em outubro de 1995.
- SP800-16 Information Technology Security Training Requirements: A Role- and Performance-Based Model (supersedes NIST Spec. Pub. 500-172), em setembro de 1997.





Principais Normas de TI e Segurança

NIST Série 800 – continuação.

- SP800-30 Risk Management Guide for Information Technology Systems, em julho de 2002.
- SP800-34 Contingency Planning Guide for Information Technology Systems, em junho de 2002.
- SP800-42 Guideline on Network Security Testing, em outubro de 2003.
- SP800-61 Computer Security Incident Handling Guide, em janeiro de 2004.
- Muitos outros guias tratando de criptografia, VPN, VoIP, Biometria, etc.





Principais Normas de TI e Segurança

BS 15000 – ano 2000.

- Desenvolvido pela British Standards Institution (BSI) e publicado em 15 de novembro de 2000.
- Primeira norma formal para *gestão de serviços de TI*.
- Embora seja *baseada no modelo de processos do ITIL*, fornece especificações claras para implementação de um processo de gestão de TI.
- O escopo da norma abrange um *sistema de gestão de serviços de TI* e forma a base para a avaliação dessa gestão.

BS 15000

BSI

Principais Normas de TI e Segurança

ISO/IEC 20000 – ano 2005.

- **Publicada pela ISO em 16 de dezembro de 2005.**
- **Evoluiu a partir da norma BS 15000 com alterações mínimas, mas passou a ser um formato internacional mais adequado para aplicação em diversos países.**
  - **ISO 20000-1: promove a adoção de processos integrados para a gestão de serviços a fim de *alcançar os requerimentos dos clientes e do negócio*.**
  - **ISO 20000-2: é um código de práticas e descreve as *melhores práticas para a gestão de serviços* dentro do escopo da ISO 20000-1.**

ISO/IEC 20000



Principais Normas de TI e Segurança

BS 7799 – início em 1995.

- Em 1995, o BSI publica a BS 7799-1:1995 (Information Technology - Code of Practice for Information Security Management).
- Proposta à ISO, em 1996, para homologação, mas foi rejeitada.
- Em 1998, a segunda parte desse documento foi publicado como BS 7799-2:1998 (Information Security Management Systems).
- Em abril de 1999, as duas normas foram publicadas após uma revisão, com o nome de BS 7799-1999.

BS 7799

BSI

Principais Normas de TI e Segurança

ISO/IEC 17799:2000 – ano 2000.

- **Homologação da BS 7799-1 em padrão ISO, sendo *composta por 10 macro controles*, cada qual subdividido em controles específicos.**
- **Primeira norma homologada a apresentar soluções para o tratamento da informação de uma maneira mais ampla.**
- **Segundo essa norma, *todo tipo de informação deve ser protegido, independentemente da sua forma de armazenamento, seja analógica ou digital, e de seu valor para a organização*.**

ISO/IEC 17799

Principais Normas de TI e Segurança

NBR ISO/IEC 17799:2001 – ano 2001.

- Em abril de 2001, a versão brasileira da norma ISO/IEC 17799:2000 foi disponibilizada para consulta pública.
- Em 01/08/2001 a ABNT homologou a versão brasileira.
- Essa norma *estabelece diretrizes e princípios gerais para iniciar, implementar, manter e melhorar a gestão de segurança da informação em uma organização*.
- Os objetivos definidos provêem diretrizes gerais sobre as metas geralmente aceitas para a gestão da segurança da informação.

NBR ISO/IEC 17799

Principais Normas de TI e Segurança

BS 7799-2:2002 – ano 2002.

- Publicada em julho de 2002.
- Foi resultado de uma revisão que visava ajustá-la com normas internacionais, tais como a ISO 9001 e a ISO 14001, e remover aspectos próprios da lei britânica.
- Os controles da ISO/IEC 17799 foram adicionados a um anexo dessa versão, permitindo uma correspondência entre a numeração em ambas as normas.

BS 7799

BSI

Principais Normas de TI e Segurança

ISO/IEC 17799:2005 – ano 2005.

- Publicada pela ISO após novas revisões.
- A ABNT rapidamente preparou a versão brasileira e no mesmo ano lançou a NBR ISO/IEC 17799:2005 revisada e atualizada.

ISO/IEC 17799

Principais Normas de TI e Segurança

Certificação de Segurança da Informação

- **Até então, o padrão ISO apenas fornecia um *guia de implementação de melhores práticas de segurança das informações* e ainda não dispusera uma norma para a certificação destas práticas.**

- **As empresas, para se certificarem, implementavam os controles previstos na ISO 17799 e se submetiam a um processo de certificação de segurança da informação baseado na norma britânica BS 7799-2.**

Principais Normas de TI e Segurança

ISO/IEC 27001:2005 – ano 2005.

- **Publicada pela ISO como a primeira norma da série 27000, que é uma nova família de normas voltadas exclusivamente para segurança da informação.**
- **Substitui a BS 7799-2, tornando-se a *norma para certificação da segurança da informação*.**
- **Nela são organizados os requisitos para estabelecer, implementar, operar, monitorar, revisar, manter e melhorar o SGSI (Sistema de Gestão da Segurança da Informação).**

ISO/IEC 27001

Principais Normas de TI e Segurança

NBR ISO/IEC 27001:2006 – ano 2006.

- Norma brasileira correspondente à ISO/IEC 27001:2005.
- Agora, para uma empresa estar certificada em um padrão internacional, basta submeter-se a um processo de auditoria baseada na norma ISO 27001.
- *A certificação agrega valor de mercado pois mostra que a empresa está apta a tratar as informações com os padrões mais exigentes e atuais de gestão da segurança das informações*.

NBR ISO/IEC 27001



Principais Normas de TI e Segurança

ISO/IEC 27000 Standards: IT - Security Techniques

- 27001: Information security management systems – Requirements
- 27002: Code of practice for information security controls
- 27003: Information security management system implementation guidance
- 27004: Information security management – Measurement
- 27005: Information security risk management
- 27006: Requirements for bodies providing audit and certification of information security management systems

ISO/IEC 27001

Principais Normas de TI e Segurança

ISO/IEC 27000 Standards: Specific contexts

- ISO/IEC 27033-1 — Network security - Part 1: Overview and concepts
- ISO/IEC 27033-2 — Network security - Part 2: Guidelines for the design and implementation of network security
- ISO/IEC 27033-3 — Network security - Part 3: Reference networking scenarios - Threats, design techniques and control issues
- ISO/IEC 27033-4 — Network security - Part 4: Securing communications between networks using security gateways
- ISO/IEC 27033-5 — Network security - Part 5: Securing communications across networks using Virtual Private Networks (VPNs)
- ISO/IEC 27033-6 — Network security - Part 6: Securing wireless IP network access

ISO/IEC 27001



Principais Normas de TI e Segurança

ISO/IEC 27000 Standards: Specific contexts

- ISO/IEC 27017 — Code of practice for information security controls based on ISO/IEC 27002 for cloud services
- ISO/IEC 27018 — Code of practice for protection of personally identifiable information (PII) in public clouds acting as PII processors
- ISO/IEC 27019 — Information security controls for the energy utility industry
- ISO/IEC 27032 — Guideline for cybersecurity
- ISO/IEC 27034-1 — Application security - Part 1: Guideline for application security
- ISO/IEC 27034-2 — Application security - Part 2: Organization normative framework
- ISO/IEC 27034-6 — Application security - Part 6: Case studies

ISO/IEC 27001



Principais Normas de TI e Segurança

ISO/IEC 27000 Standards: Specific contexts

- ISO/IEC 27035-1 — Information security incident management - Part 1: Principles of incident management
- ISO/IEC 27035-2 — Information security incident management - Part 2: Guidelines to plan and prepare for incident response

- ISO/IEC 27036-1 — Information security for supplier relationships - Part 1: Overview and concepts
- ISO/IEC 27036-2 — Information security for supplier relationships - Part 2: Requirements
- ISO/IEC 27036-3 — Information security for supplier relationships - Part 3: Guidelines for information and communication technology supply chain security
- ISO/IEC 27036-4 — Information security for supplier relationships - Part 4: Guidelines for security of cloud services

ISO/IEC 27001



Principais Normas de TI e Segurança

ISO/IEC 27000 Standards: Specific contexts

- ISO/IEC 27037 — Guidelines for identification, collection, acquisition and preservation of digital evidence
- ISO/IEC 27041 — Investigation assurance
- ISO/IEC 27042 — Analyzing digital evidence
- ISO/IEC 27043 — Incident investigation

- ISO/IEC 27039 — Intrusion prevention
- ISO/IEC 27040 — Storage security

ISO/IEC 27001



Principais Normas de TI e Segurança

ISO/IEC 27000 Standards: Specific contexts

- ISO/IEC 27701 — Information technology - Security Techniques - Information security management systems — Privacy Information Management System (PIMS).
- ISO 27789 — Health informatics — Audit trails for electronic health records
- ISO 27799 — Information security management in health using ISO/IEC 27002

ISO/IEC 27001



NBR ISO/IEC 27001:2006

Processo de Certificação

- A norma fornece os requisitos de como uma organização pode implementar as melhores práticas de segurança, independente da necessidade de certificação do SGSI.

- Para obter a certificação, seja para garantir transparência, demonstrar preocupação com a segurança de dados de terceiros, blindar a parte jurídica, ou qualquer outro benefício que possa ser alcançado, é necessário uma entidade externa qualificada e credenciada para realizar o processo de certificação e emitir o certificado.

NBR ISO/IEC 27001:2006

Processo de Certificação: Fatores que contribuem para obter a certificação.

- Apoio e conscientização da alta direção são fundamentais para a implementação do processo;
- Colaboração de auditores externos em consultoria é necessária;
- Designação de uma pessoa ou setor responsável pelo processo facilita as ações a serem desenvolvidas;
- Definição de um cronograma a ser seguido durante o processo colabora para a integração de toda a empresa (direção/funcionários);
- Treinamento envolvendo todos é fundamental para atingir os objetivos traçados.

NBR ISO/IEC 27001:2006

Processo de Certificação: Passos Gerais

- Definir as diretrizes da política;
- Definir o escopo;
- Realizar uma criteriosa análise de risco;
- Definir os objetivos de controle e os controles;
- Implementar os controles;
- Preparar a Declaração de Aplicabilidade;
- Passar pela auditoria final.

NBR ISO/IEC 27001:2006

Processo de Certificação: Benefícios

- A certificação ISO 27001 traz uma série de benefícios, pois:
  - Cria credibilidade,
  - Demonstra um maior rigor e formalidade no trato dos dados e informações,
  - Aumenta a maturidade e confiança,
  - Estabelece responsabilidades,
  - Foca na prevenção de danos,
  - Diminui os riscos, e
  - Resulta num excelente diferencial de mercado.

NBR ISO/IEC 27001:2006

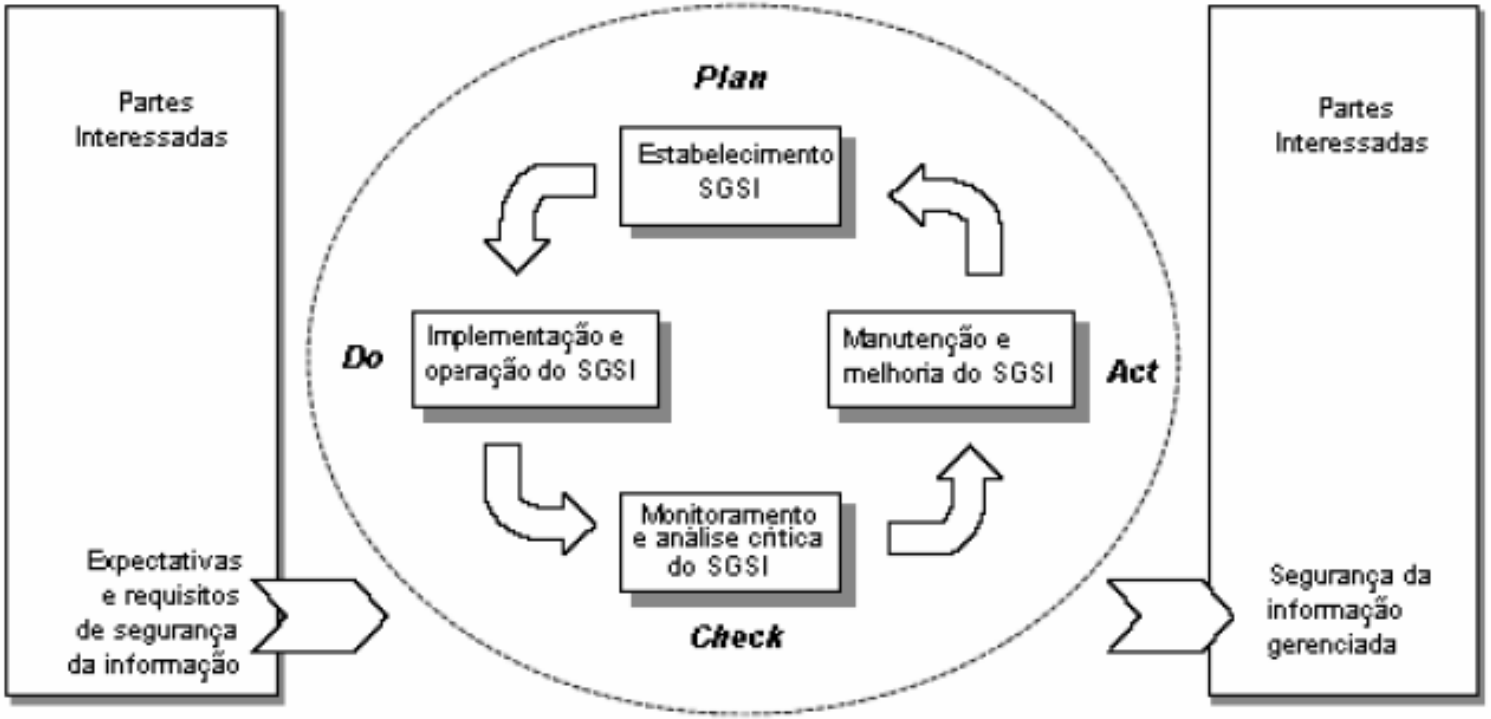
Processo de Implantação: Ciclo Plan-Do-Check-Act (PDCA)

- O ciclo leva em consideração os princípios para governar a segurança de sistemas de informação e redes das diretrizes da OECD (Organisation for Economic Co-operation and Development), que são:
  - Conscientização,
  - Responsabilidade,
  - Resposta,
  - Análise/avaliação de riscos,
  - Arquitetura e implementação de segurança,
  - Gestão de segurança e reavaliação.

OECD

NBR ISO/IEC 27001:2006

Processo de Implantação: Ciclo Plan-Do-Check-Act (PDCA)



NBR ISO/IEC 27001:2006

Processo de Implantação: Ciclo Plan-Do-Check-Act (PDCA)

- **Plan (planejar) – Estabelecer o SGSI. A política, os objetivos, os processos e os procedimentos do SGSI devem ser criados nessa fase, tendo o foco na gestão dos riscos e melhoria da segurança da informação para produzir os resultados almejados.**

- **Do (fazer) – Executar as ações para implementar o SGSI. Implementar e operar a política, os controles, os processos e os procedimentos do SGSI.**

NBR ISO/IEC 27001:2006

Processo de Implantação: Ciclo Plan-Do-Check-Act (PDCA)

- **Check (checar) – Monitorar e analisar criticamente o SGSI. Avaliar e, quando aplicável, medir o desempenho de um processo frente à política, objetivos e experiências práticas de gestão, apresentando os resultados para uma análise crítica pela direção.**

- **Act (agir) – Manter e melhorar o SGSI. Executar as ações corretivas e preventivas, com base nos relatórios das auditorias internas e da análise crítica pela direção ou outras informações pertinentes, visando alcançar a melhoria contínua do SGSI.**

NBR ISO/IEC 27001:2006

Processo de Implantação: Seqüência de processos obrigatória para certificação.

- Sistema de Gestão de Segurança da Informação (SGSI)
- Responsabilidade de Gestão
- Auditorias Internas de SGSI
- Análise Crítica pela Direção do SGSI
- Melhoria do SGSI

NBR ISO/IEC 27001:2006

Processo de Implantação: Sistema de Gestão de Segurança da Informação (SGSI)

- **Consiste em estabelecer, implementar, operar, monitorar, analisar criticamente, manter e melhorar um SGSI documentado dentro do contexto das atividades de negócio globais da organização e os riscos que ela enfrenta.**

- **É preciso harmonizar uma série de fatores que englobam aspectos técnicos sobre a implementação e aspectos jurídicos para se evitar infrações civis e penais durante um monitoramento.**

NBR ISO/IEC 27001:2006

Processo de Implantação: Responsabilidade de Gestão

- **Quesitos que devem ser atendidos:**
  - **Comprometimento da direção;**
    - **Envolve a direção no processo decisório para fornecer uma evidência incontestável de comprometimento da direção e da sua responsabilidade na gestão do SGSI.**
  - **Gestão de recursos.**
    - **Provisão de recursos;**
      - **Investimento financeiro, humano e/ou material.**
    - **Treinamento, conscientização e competência.**
      - **Todo o pessoal que tem responsabilidades atribuídas no SGSI devem ser competentes e capacitadas a desempenhar suas tarefas.**
      - **Deve-se assegurar que todo o seu pessoal esteja consciente da relevância e importância das suas atividades e de como eles contribuem para o alcance dos objetivos do SGSI.**

NBR ISO/IEC 27001:2006

Processo de Implantação: Auditorias Internas de SGSI

- Consiste em verificar se processos e controles implementados estão atendendo aos requisitos de segurança da informação, normas, regulamentos, etc.
- Deve-se definir um escopo, freqüência, critérios e métodos para a auditoria.
- O processo de auditoria exige um procedimento documentado, abordando as responsabilidades, requisitos de planejamento e execução, além dos registros dos resultados.

NBR ISO/IEC 27001:2006

Processo de Implantação: Análise Crítica pela Direção do SGSI

- **Deve ser realizada pela direção da organização em intervalos planejados (pelo menos uma vez ao ano) visando garantir a pertinência, adequação e eficácia do SGSI.**

- **Entradas para análise crítica**
  - **Resultados de auditorias internas realizadas; vulnerabilidades e ameaças não contempladas anteriormente; etc.**

- **Saída da análise crítica**
  - **Ações para melhoria da eficácia do SGSI; atualização da análise/avaliação dos riscos; e, a modificação de procedimentos e controles.**

NBR ISO/IEC 27001:2006

Processo de Implantação: Melhoria do SGSI

- **Quesitos que devem ser atendidos:**
  - **Melhoria contínua;**
    - **Realização de auditorias internas; análises críticas; implementação de ações corretivas e preventivas; etc.**
  - **Ação corretiva;**
    - **Ação executada pela organização para eliminar a causa e a repetição de qualquer não-conformidade observada nas fases do SGSI.**
  - **Ação preventiva.**
    - **Ação para eliminar as causas de não-conformidades potenciais com os requisitos do SGSI, de forma a evitar a sua ocorrência.**

NBR ISO/IEC 27002:2013

Controles da Norma (derivados da NBR ISO/IEC 17799:2005)

- Políticas de Segurança da Informação
- Organização da Segurança da Informação
- Segurança em Recursos Humanos
- Gestão de Ativos
- Segurança Física e do Ambiente
- Controle de Acesso
- Criptografia
- Segurança nas Operações
- Segurança nas Comunicações
- Aquisição, Desenvolvimento e Manutenção de Sistemas
- Relacionamento na Cadeia de Suprimento
- Gestão de Incidentes de Segurança da Informação
- Gestão da Continuidade do Negócio
- Conformidade

NBR ISO/IEC 27002:2022

Controles da Norma (derivados da NBR ISO/IEC 27002:2013)

- **Organizados em cinco categorias (temas):**
  - **Organizacionais**
  - **Pessoas**
  - **Físico**
  - **Tecnológico**

NBR ISO/IEC 27002:2022

Controles da Norma (derivados da NBR ISO/IEC 27002:2013)

- Associados a cinco atributos:

- **Tipo de Controle:**
  - Preventivo
  - Detectivo
  - Corretivo

- **Propriedades de Segurança da Informação:**
  - Confidencialidade
  - Integridade
  - Disponibilidade

- **Conceitos de Segurança da Informação:**
  - Identificar
  - Proteger
  - Detectar
  - Responder
  - Recuperar

NBR ISO/IEC 27002:2022

Controles da Norma (derivados da NBR ISO/IEC 27002:2013)

- Associados a cinco atributos:
- Capacidades Operacionais:
  - Governança
  - Gestão de Ativos
  - Proteção da Informação
  - Segurança em Recursos Humanos
  - Segurança Física
  - Segurança de Sistemas e Redes
  - Segurança de Aplicações
  - Configuração Segura
  - Gestão de Identidade e Acesso
  - Gestão de Ameaças e Vulnerabilidades
  - Continuidade
  - Segurança do Relacionamento na Cadeia de Suprimentos
  - Legal e Compliance
  - Gestão de Eventos de Segurança da Informação
  - Garantia de Segurança da Informação

NBR ISO/IEC 27002:2022

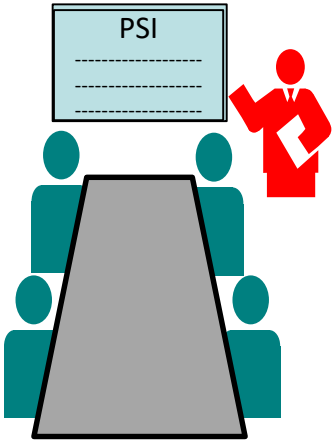
Controles da Norma (derivados da NBR ISO/IEC 27002:2013)

- Associados a cinco atributos:
- Domínios de Segurança:
  - Governança e Ecossistema
    - Governança do Sistema de Segurança da Informação e Gestão de Riscos
    - Gestão de Segurança Cibernética do Ecossistema
  - Resiliência
    - Operações de Continuidade
    - Gestão de Crises
  - Proteção
    - Arquitetura de Segurança de TI
    - Administração de Segurança de TI
    - Gestão de Identidade e Acesso
    - Manutenção de Segurança de TI
    - Segurança Física e Ambiental
  - Defesa
    - Detectar
    - Gestão de Incidentes de Segurança Computacional

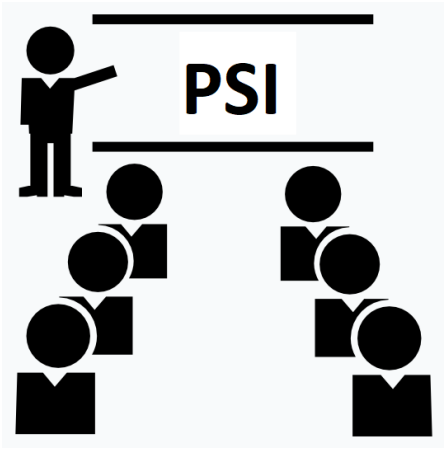
Melhores práticas de segurança da informação

Controles da Norma: Políticas de Segurança da Informação (PSI)

- **A implantação da segurança da informação deve ser top-down!!!**
  - **A direção da organização deve elaborar, aprovar e divulgar as diretrizes de segurança da informação que vão reger as operações da organização, observando os requisitos do negócio, a legislação e a regulamentação.**



Elaborar e aprovar as PSI



Divulgar as PSI para todos os funcionários e colaboradores externos

Melhores práticas de segurança da informação

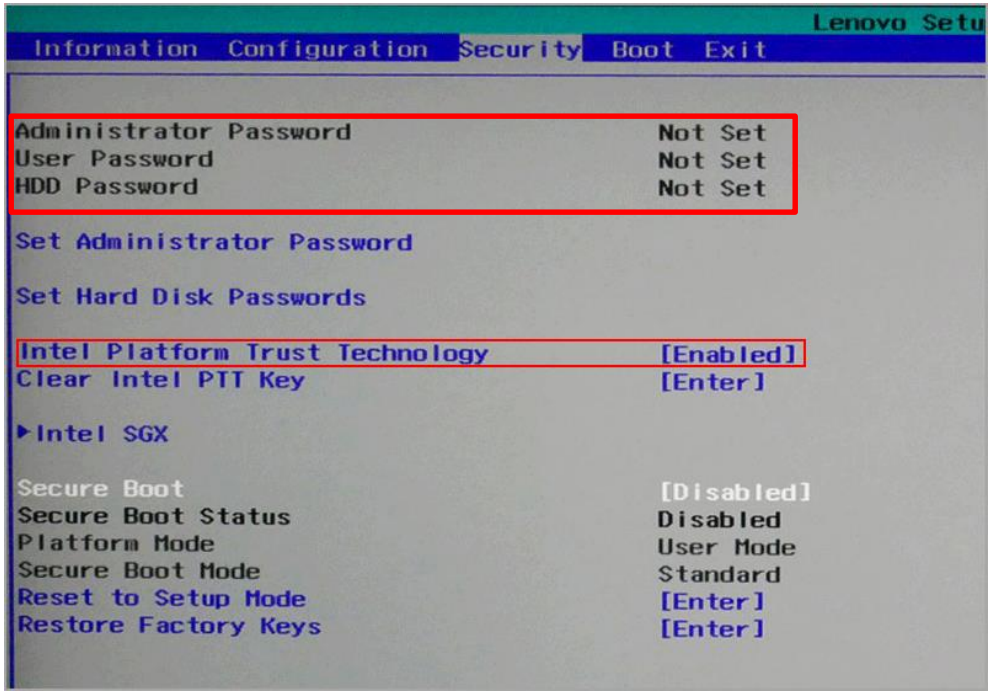
Controles da Norma: Organização da Segurança da Informação

- **A empresa deve se organizar para fazer a implantação de SI...**
  - **Viabilizar a gestão da implantação do programa de segurança da informação na organização.**
  - **Definir as responsabilidades de todos os colaboradores com relação à segurança da informação.**
  - **Definir as áreas de responsabilidade visando a minimizar as chances de modificação não autorizada ou não intencional, ou uso indevido dos ativos da organização.**
  - **Estreitar a relação com autoridades relevantes para a operação da empresa, e manter contato com grupos, associações e fóruns especializados de segurança da informação.**
  - **Incorporar a segurança da informação na gestão de todos os projetos da organização.**

Melhores práticas de segurança da informação

Controles da Norma: Organização da Segurança da Informação

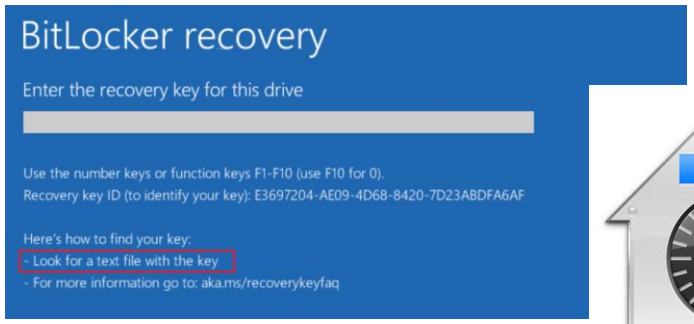
- **Atenção especial com os dispositivos móveis e o trabalho remoto!**
  - **Implantar procedimentos de segurança da informação para minimizar os riscos no trabalho remoto e no uso de dispositivos móveis.**
  - **Proteção contra acesso não autorizado às configurações.**
  - **Proteção contra inicialização não autorizada.**
  - **Criptografia em hardware para os discos internos.**

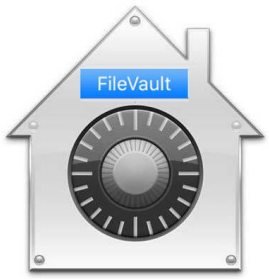


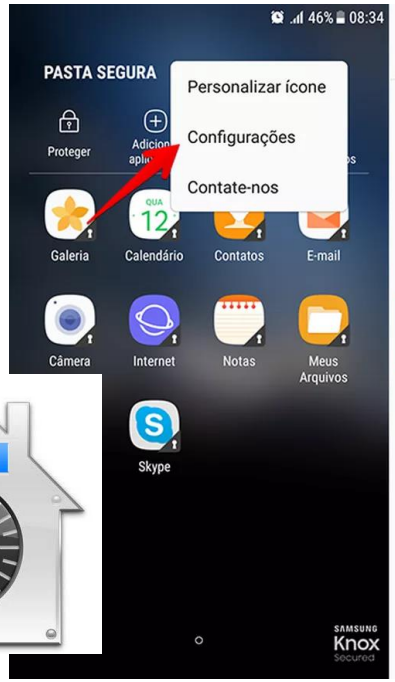
Melhores práticas de segurança da informação

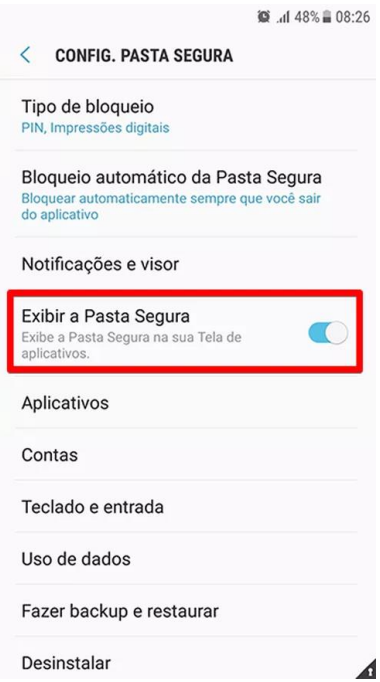
Controles da Norma: Organização da Segurança da Informação

- **Atenção especial com os dispositivos móveis e o trabalho remoto!**
  - **Implantar procedimentos de segurança da informação para minimizar os riscos no trabalho remoto e no uso de dispositivos móveis.**
  - **Criptografia de pastas ou do disco nos sistemas operacionais.**









Melhores práticas de segurança da informação

Controles da Norma: Segurança em Recursos Humanos

- **A contratação de pessoal deve atender os requisitos de segurança da informação inerentes aos cargos que devem ser preenchidos.**
  - **Adotar um processo de seleção assertiva de funcionários e colaboradores externos para garantir que ambos estarão em conformidade com seus respectivos papéis e cientes das suas respectivas responsabilidades.**
  - **Pesquisar o histórico dos candidatos e verificar pontos impeditivos ou não condizentes com as atividades dos cargos que serão exercidos, requisitos do negócio e riscos à segurança das informações.**
  - **Os funcionários e colaboradores externos devem concordar e assinar os termos e condições da contratação que, por sua vez, devem apresentar, de forma clara e inequívoca, as suas responsabilidade com a segurança da informação.**

Melhores práticas de segurança da informação

Controles da Norma: Segurança em Recursos Humanos

- **O desenvolvimento da cultura da segurança da informação requer uma ação contínua da organização.**
  - **Promover ações para desenvolver a conscientização dos funcionários e colaboradores externos quanto as suas responsabilidades pela segurança da informação.**
  - **Fomentar a prática da segurança da informação conforme estabelecido pelas políticas e procedimentos da organização.**
  - **Fornecer treinamento específico sobre a política e os procedimentos da organização.**
  - **Definir um processo disciplinar formal para tomar ações contra violação da segurança da informação.**

Melhores práticas de segurança da informação

Controles da Norma: Segurança em Recursos Humanos

- **As movimentações de pessoal podem impactar na segurança da informação e devem ser tratadas com cuidado.**
  - **Resguardar os interesses da organização quando ocorre mudança ou encerramento da contratação do funcionário ou colaborador externo.**
  - **Instruir os funcionários e colaboradores externos a observarem com atenção todas as suas responsabilidades e obrigações pela segurança da informação da organização que permanecerão válidas após o encerramento ou mudança da contratação.**

Melhores práticas de segurança da informação

Controles da Norma: Gestão de Ativos

- **É fundamental cumprir as regras de uso de cada ativo de informação!**
  - **Identificar os ativos da organização e definir as devidas responsabilidades pela proteção dos ativos, as regras de uso para cada ativo e os sistemas de processamento autorizados a manipular com os ativos de informação.**

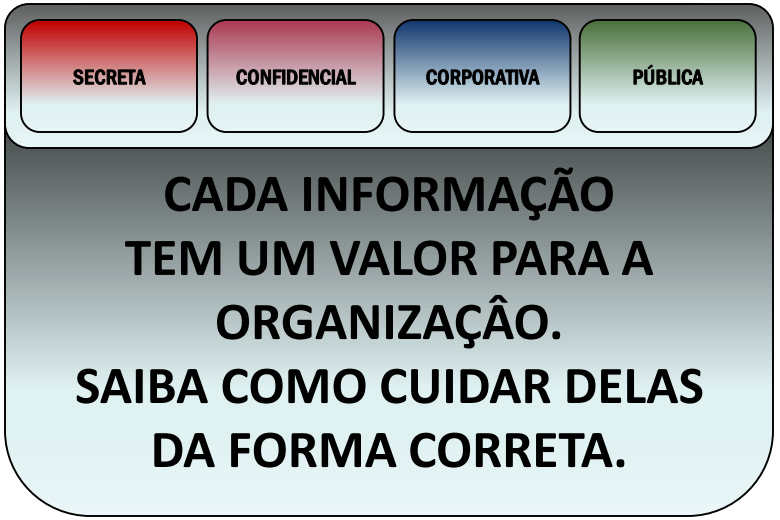
Ativo (PSI – 2020/1)	Proprietário (PSI – 2020/1)	Regras de uso (RUI – 2020/5)	Processamento (RUI – 2020/5)
Pessoal	RH	R1, R2, R3	P1, P2, P3, P4
Clientes	Comercial	R4, R5, R6, R7	P5, P6, P7
Fornecedores	Comercial	R4, R5, R6	P6, P7
Administrativa	Administrativo	R10, R11, R12	P1, P2, P3, P5, P7
Financeira	Financeiro	R1, R2, R3, R4	P5, P6, P7
Informática	TI	R20, R21, R22, R23, R24	P10, P11, P12

PSI – Política de Segurança da Informação
RUI – Regras de Uso da Informação
Rn – identificação de uma regra da RUI
Pn – identificação de um sistema de processamento

Melhores práticas de segurança da informação

Controles da Norma: Gestão de Ativos

- **É fundamental fazer a classificação dos ativos de informação!**
  - **Determinar o tratamento apropriado para cada categoria de informação de acordo com o seu grau de importância na organização.**
  - **Descrever o tratamento apropriado:**
    - **Recebimento**
    - **Elaboração**
    - **Manuseio**
    - **Reprodução**
    - **Divulgação**
    - **Guarda**
    - **Transporte**
    - **Descarte**



Melhores práticas de segurança da informação

Controles da Norma: Gestão de Ativos

- **As mídias removíveis requerem especial atenção!**
  - **Proteger a informação armazenada nas mídias removíveis contra a divulgação não autorizada, modificação, remoção ou destruição.**
  - **Armazenamento seguro:**



Fonte: Kingston Technology WebSite
URL: https://www.kingston.com/br/usb-flash-drives/datatraveler-2000-encrypted-usb-flash-drive



Fonte: Corsair WebSite
URL: https://www.corsair.com/eu/en/Categories/Products/Storage/USB-Drives/flash-padlock-3-config/p/CMFPLA3B-16GB



Fonte: Lexar WebSite
URL: https://www.lexar.com/portfolio_page/jumpdrive-fingerprint-f35-usb-3-0-flash-drive/

Melhores práticas de segurança da informação

Controles da Norma: Gestão de Ativos

- **As mídias removíveis requerem especial atenção!**
  - **Proteger a informação armazenada nas mídias removíveis contra a divulgação não autorizada, modificação, remoção ou destruição.**
  - **Descarte seguro via Hardware: Fragmentadores**



Fonte: Riotron WebSite
URL http://riotron.com.br/loja/fragmentadora-hsm-powerline-hds-150/



Fonte: Casa das Fragmentadoras WebSite
URL: https://www.casadasfragmentadoras.com.br/aluguel-fragmentadora-papel/destruicao-de-hds/



Fonte: Aurora WebSite
URL: https://aurora.com.sg/product/as1060sb/

Melhores práticas de segurança da informação

Controles da Norma: Gestão de Ativos

- **As mídias removíveis requerem especial atenção!**
  - **Proteger a informação armazenada nas mídias removíveis contra a divulgação não autorizada, modificação, remoção ou destruição.**
  - **Descarte seguro via Software: Destruidores de Arquivos**
    - **Operação Delete apenas apaga os metadados do sistema de arquivos, como nome do arquivo, proprietário, data de criação e acesso, permissões e localização dos blocos de dados, e libera os blocos de dados do arquivo.**
    - **Operação Destruir (Shred) limpa (Wipe) os blocos de dados do arquivo e os metadados do sistema de arquivos fazendo a sobreposição dos dados, e depois libera os blocos de dados limpos.**



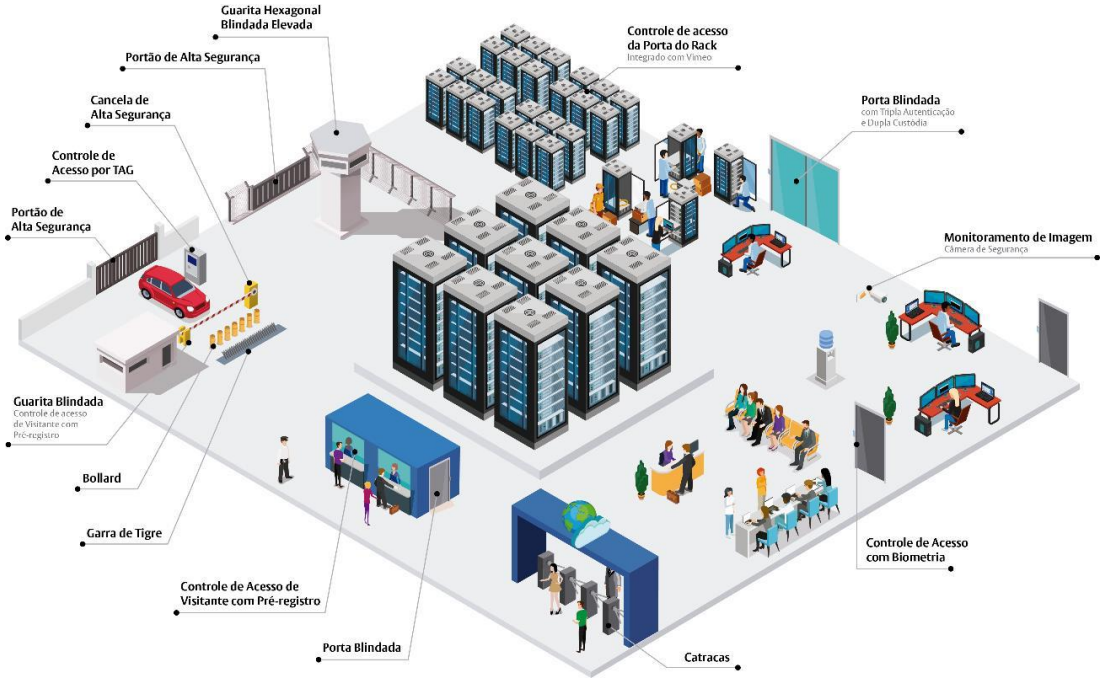
BleachBit

Fonte: BleachBit WebSite
URL: https://docs.bleachbit.org/doc/shred-files-and-wipe-disks.html

Melhores práticas de segurança da informação

Controles da Norma: Segurança Física e do Ambiente

- **O ambiente no qual a informação circula deve ser protegido!**
  - **Proteger as áreas que processam ou armazenam informação contra o acesso físico não autorizado, danos e comprometimento de informação.**

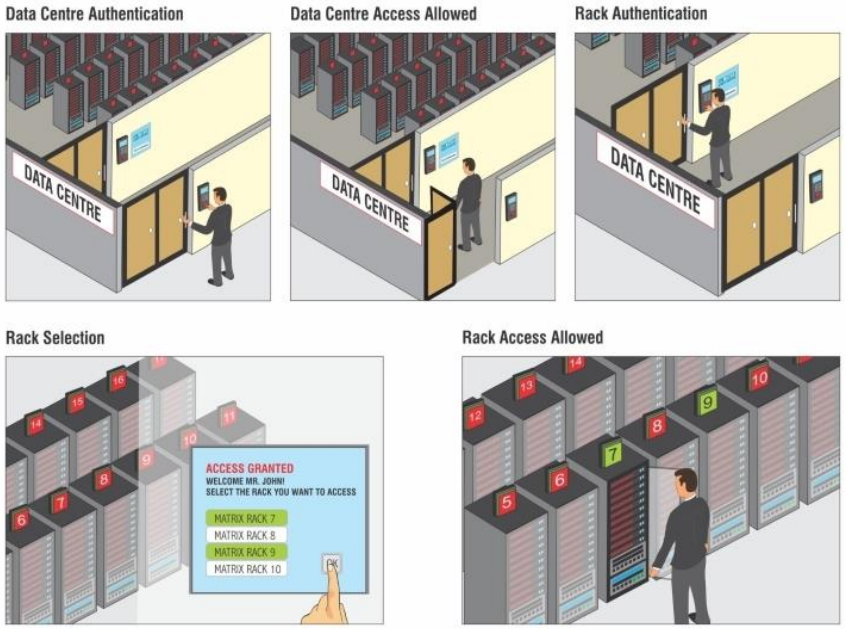


Fonte: Vault Assa Abloy - URL: http://materiais.vault.com.br/vault-novo-normal

Melhores práticas de segurança da informação

Controles da Norma: Segurança Física e do Ambiente

- **O ambiente no qual a informação circula deve ser protegido!**
  - **Proteger as áreas que processam ou armazenam informação contra o acesso físico não autorizado, danos e comprometimento de informação.**



Fonte: Security Informed Website - URL: https://www.securityinformed.com/news/matrix-comsec-presents-biometric-access-control-co-6908-ga-npr.1524722174.html?utm_source=SSc%20International%20Edition&utm_medium=Redirect&utm_campaign=International%20Redirect%20Popup

Melhores práticas de segurança da informação

Controles da Norma: Segurança Física e do Ambiente

- **O ambiente no qual a informação circula deve ser protegido!**
  - **Proteger as áreas que processam ou armazenam informação contra o acesso físico não autorizado, danos e comprometimento de informação.**



Fonte: Digitus Biometrics Website
URL: https://digitus-biometrics.com/products/server-cabinet-locks/

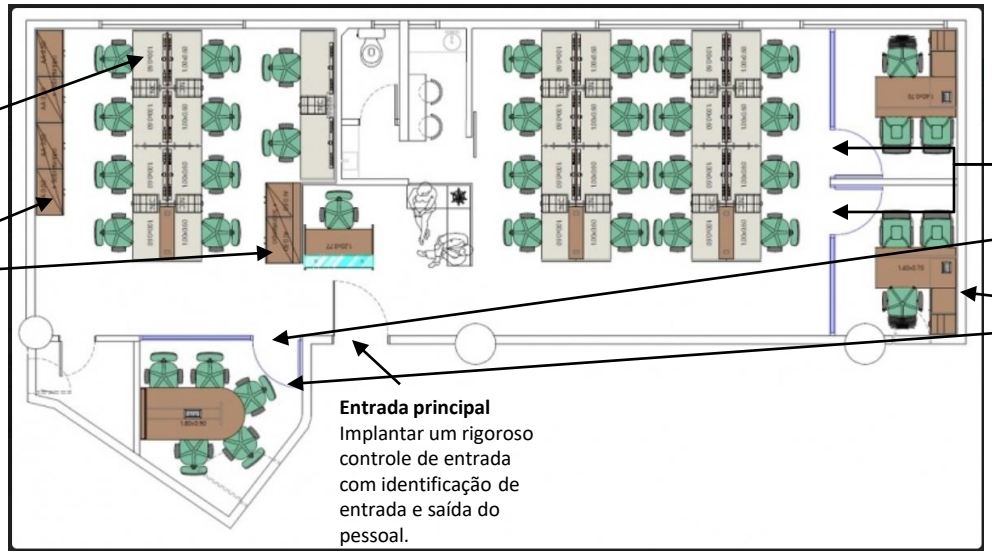


Fonte: Security WorldMarket Website
URL: https://www.securityworldmarket.com/uk/News/Business-News/securing-data-the-importance-of-physical-security-for-servers

Melhores práticas de segurança da informação

Controles da Norma: Segurança Física e do Ambiente

- **Os equipamentos devem ser protegidos dentro e fora da organização!**
  - **Proteger contra a perda, dano, furto ou comprometimento de ativos e evitar a interrupção das operações da organização.**
  - **Instalação dos equipamentos em locais que reduzam os riscos.**

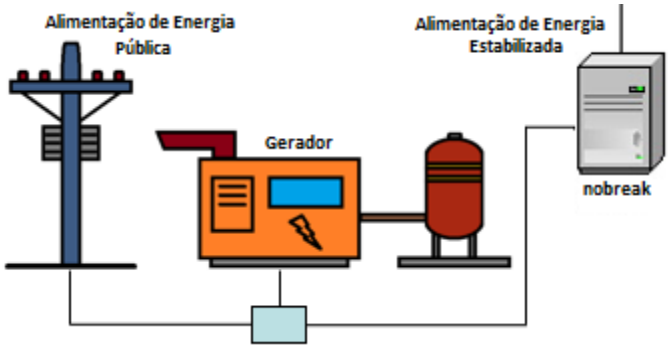


Fonte: Projeto Promov - Cotanet! Website
URL: http://moveis.cotanet.com.br/projetos-e-layout/layout-para-empresa

Melhores práticas de segurança da informação

Controles da Norma: Segurança Física e do Ambiente

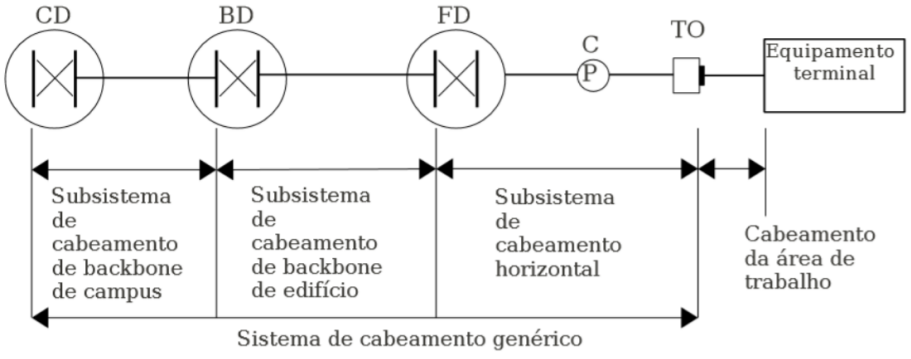
- **Os equipamentos devem ser protegidos dentro e fora da organização!**
  - **Proteger contra a perda, dano, furto ou comprometimento de ativos e evitar a interrupção das operações da organização.**
  - **Proteção contra falta de energia elétrica.**

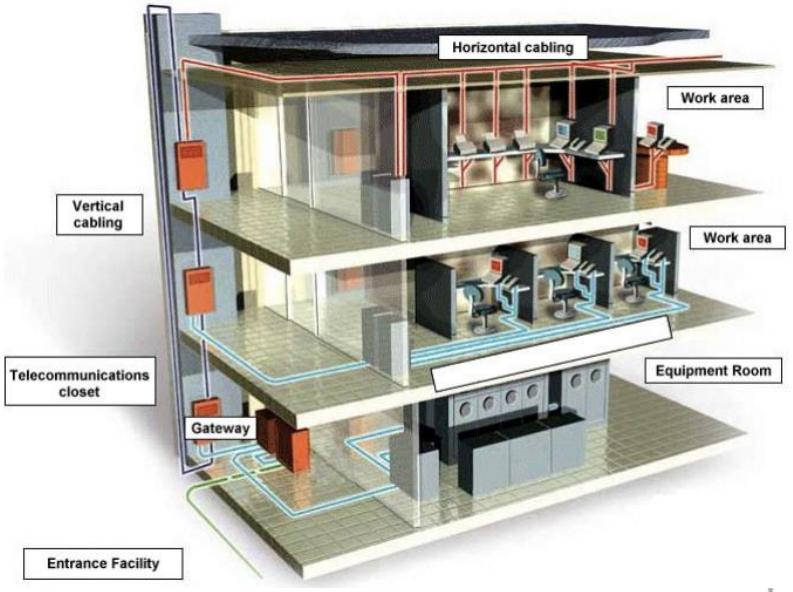


Melhores práticas de segurança da informação

Controles da Norma: Segurança Física e do Ambiente

- **Os equipamentos devem ser protegidos dentro e fora da organização!**
  - **Proteger contra a perda, dano, furto ou comprometimento de ativos e evitar a interrupção das operações da organização.**
  - **Cabeamento estruturado: NBR-14565**



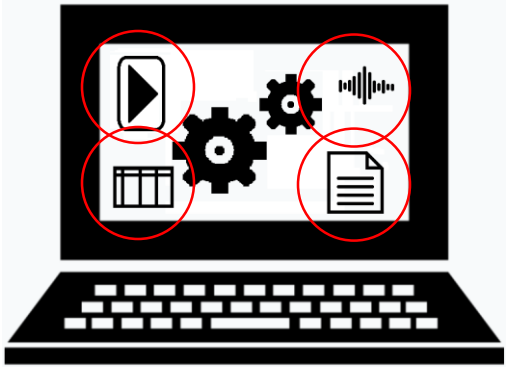


  - **CD - Campus Distributor**
  - **BD – Building Distributor**
  - **FD – Floor Distributor**
  - **CP – Consolidation Point**
  - **TO – Telecomunnication Outlet**

Melhores práticas de segurança da informação

Controles da Norma: Segurança Física e do Ambiente

- **Os equipamentos devem ser protegidos dentro e fora da organização!**
  - **Proteger contra a perda, dano, furto ou comprometimento de ativos e evitar a interrupção das operações da organização.**
  - **Manutenção correta e periódica para reduzir o risco de indisponibilidade.**
    - **Os procedimentos de manutenção devem considerar os riscos de acesso não autorizado à informação armazenada nos equipamentos.**



Melhores práticas de segurança da informação

Controles da Norma: Segurança Física e do Ambiente

- **Os equipamentos devem ser protegidos dentro e fora da organização!**
  - **Proteger contra a perda, dano, furto ou comprometimento de ativos e evitar a interrupção das operações da organização.**
  - **Utilização do cordão de aço para proteção física do equipamento.**





Melhores práticas de segurança da informação

Controles da Norma: Segurança Física e do Ambiente

- **Os equipamentos devem ser protegidos dentro e fora da organização!**
  - **Proteger contra a perda, dano, furto ou comprometimento de ativos e evitar a interrupção das operações da organização.**
  - **Remover todas as informações sensíveis e licenças de software antes de fazer a reutilização de equipamentos.**



Melhores práticas de segurança da informação

Controles da Norma: Segurança Física e do Ambiente

- **Os equipamentos devem ser protegidos dentro e fora da organização!**
  - **Proteger contra a perda, dano, furto ou comprometimento de ativos e evitar a interrupção das operações da organização.**
  - **Adoção de política de mesa limpa e tela limpa.**



Fonte: Época Negócios Website
URL: https://epocanegocios.globo.com/Inspiracao/Carreira/noticia/2012/03/quer-deixar-uma-boa-impressao-no-trabalho-esta-na-hora-de-limpar-mesa.html



Fonte: PPLWARE Website
URL: https://pplware.sapo.pt/apple/ha-cada-vez-mais-empresas-a-adotar-por-computadores-mac-no-local-de-trabalho

Melhores práticas de segurança da informação

Controles da Norma: Controle de Acesso

- **É importante fazer um rigoroso gerenciamento do acesso do usuário!**
  - **Permitir acesso aos sistemas de informação apenas para usuários autorizados.**
  - **Formalizar o processo de registro e o cancelamento das contas de acesso dos usuários do sistema de informação.**
  - **Formalizar o processo de concessão e revogação dos direitos de acesso dos usuários do sistema de informação.**
  - **Formalizar o processo de concessão, delegação e uso de direitos de acesso privilegiado.**
  - **Incluir o processo de revogação dos direitos de acesso dos usuários quando ocorrer o encerramento ou mudança de suas atividades ou contratos.**

Melhores práticas de segurança da informação

Controles da Norma: Controle de Acesso

- **Os usuários devem ser conscientizados sobre suas responsabilidade!**
  - **Conscientizar os usuários sobre a responsabilidade na proteção das suas credenciais de autenticação dos sistemas de informação.**
  - **Orientar os usuários a seguir boas práticas da organização quanto ao uso e a guarda das credenciais de autenticação (ex: senha, token, biometria).**
  - **Orientar os usuários a não utilizar as credenciais de autenticação usadas no sistema corporativo em sistemas externos.**

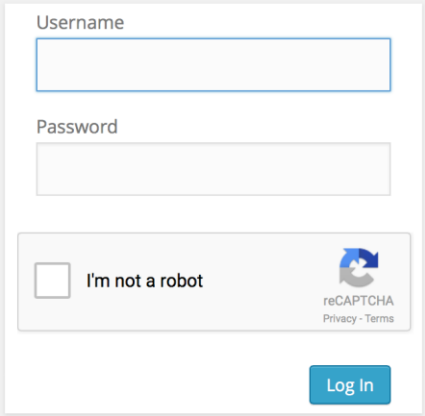


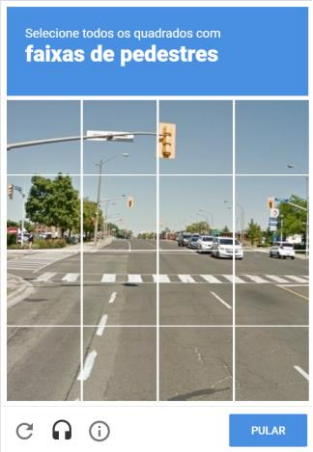
Fonte: Oficina da Net Website
URL: https://www.oficinadanet.com.br/post/18142-as-senhas-mais-usadas-em-2016-sera-que-a-sua-e-uma-delas

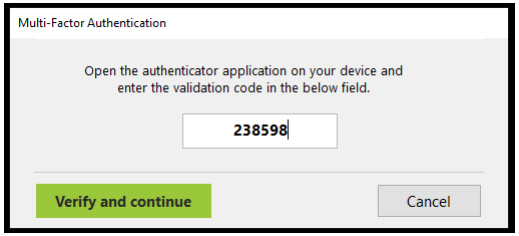
Melhores práticas de segurança da informação

Controles da Norma: Controle de Acesso

- **É importante controlar o acesso aos sistemas e às aplicações!**
  - **Permitir o acesso dos usuários autorizados apenas às funcionalidades do sistema ou aplicação referentes ao seu nível de acesso.**
  - **Utilizar um processo seguro de entrada e saída no sistema (sign-in e sign-out), preferencialmente com autenticação multifator (múltiplas etapas de autenticação) e sistema anti-robô.**







Fonte: UserLock – Leverage Website
URL: https://leverage.inf.br/produtos-userlock/

DEPARTAMENTO DE INFORMÁTICA PUC·RIO

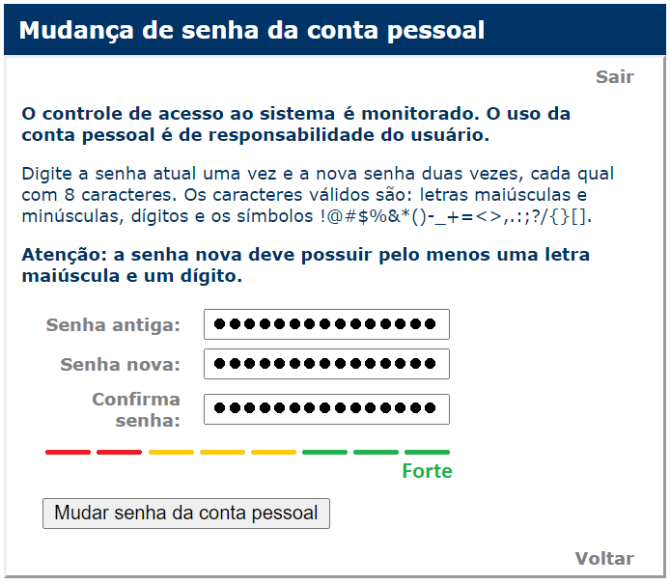
PUC RIO

Melhores práticas de segurança da informação

Controles da Norma: Controle de Acesso

- **É importante controlar o acesso aos sistemas e às aplicações!**
  - **Permitir o acesso dos usuários autorizados apenas às funcionalidades do sistema ou aplicação referentes ao seu nível de acesso.**
  - **Cadastramento de senha com indicação dos requisitos e nível de qualidade da senha.**
  - **Processo de recadastramento com confirmação de posse de telefone ou e-mail.**





Melhores práticas de segurança da informação

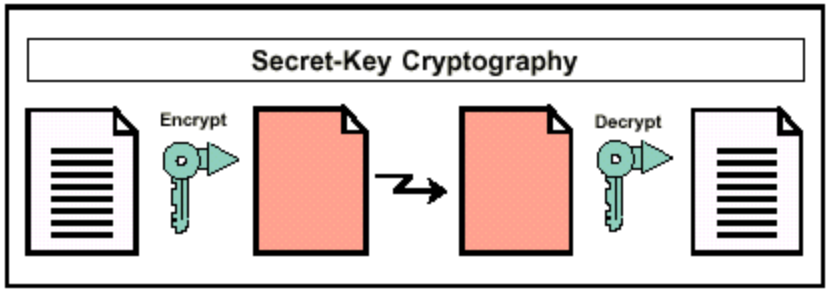
Controles da Norma: Criptografia

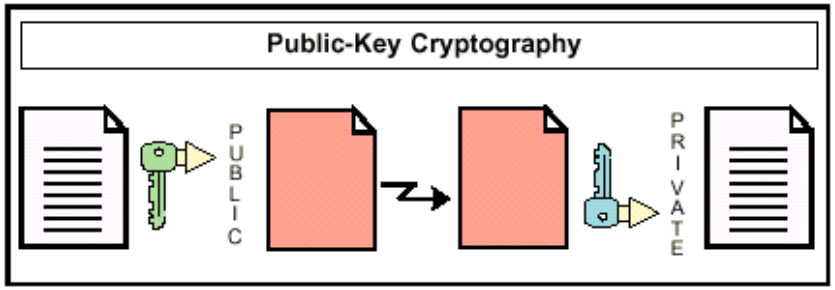
- **Determinar uma política de uso dos controles criptográficos.**
  - **Proteger a integridade, autenticidade e confidencialidade (sigilo) das informações com criptografia.**
  - **Determinar os algoritmos criptográficos que devem ser usados para garantir a integridade, autenticidade e o sigilo das informações.**
  - **Verificar a necessidade de utilizar uma infraestrutura de chaves públicas (Pública e/ou Privada).**
  - **Determinar as políticas de uso e gerenciamento das chaves criptografadas:**
    - **Operações permitidas;**
    - **Controle de proteção;**
    - **Prazo de validade;**
    - **Controle de revogação e renovação;**
    - **Controle de descarte.**

Melhores práticas de segurança da informação

Controles da Norma: Criptografia

- **Determinar uma política de uso dos controles criptográficos.**
  - **Proteger a integridade, autenticidade e confidencialidade (sigilo) das informações com criptografia.**

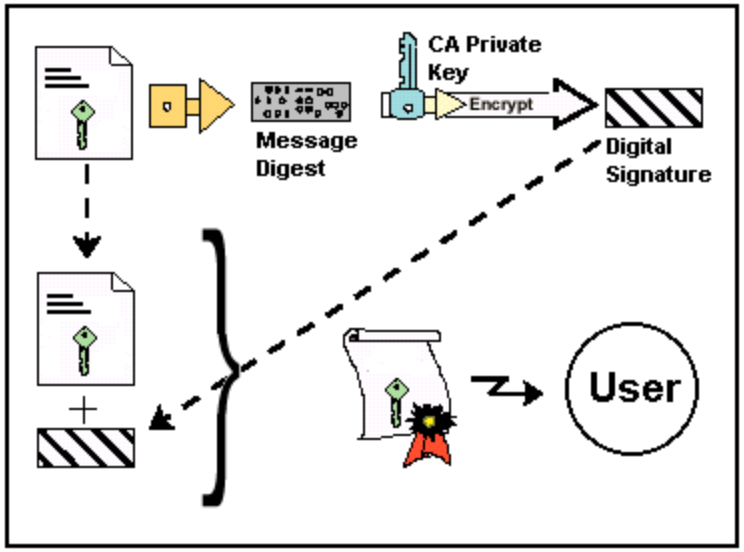




Melhores práticas de segurança da informação

Controles da Norma: Criptografia

- **Determinar uma política de uso dos controles criptográficos.**
  - **Proteger a integridade, autenticidade e confidencialidade (sigilo) das informações com criptografia.**



Melhores práticas de segurança da informação

Controles da Norma: Segurança nas Operações

- **Formalização dos Procedimentos Operacionais**
  - **Garantir a operação segura e correta dos recursos de processamento da informação.**
  - **Documentar e disponibilizar os procedimentos de operação para todos os usuários que necessitem deles.**
  - **Controlar as mudanças na organização, nos processos de negócio, nos recursos de processamento da informação e nos sistemas que afetam a segurança da informação.**
  - **Monitorar e ajustar a utilização dos recursos, e projetar as necessidades de capacidade futura para garantir o desempenho requerido do sistema.**
  - **Reduzir o risco de acessos ou modificações não autorizados no ambiente de produção.**

Melhores práticas de segurança da informação

Controles da Norma: Segurança nas Operações

- **É fundamental implantar proteção contra malware!**
  - **Proteger as informações e os sistemas de processamento das informações contra as ações dos códigos maliciosos (malware).**
  - **Implantar soluções anti-malware em todos os equipamentos que processam informação e elaborar um programa de treinamento específico para dos usuários.**

kaspersky McAfee Bitdefender avast AVG AV-TEST The Independent IT-Security Institute Magdeburg Germany

Melhores práticas de segurança da informação

Controles da Norma: Segurança nas Operações

- **É fundamental ter cópia de segurança dos ativos de informação!**
  - **Possibilitar a restauração das informações danificadas ou perdidas.**
  - **Implantar procedimentos para executar e testar as cópias de segurança das informações e dos sistemas de processamento das informações.**
  - **Assegurar a integridade, autenticidade e sigilo das cópias de segurança das informações.**
  - **Arquivar as cópias de segurança das informações em local seguro externo (off-site) à organização.**
    - **Ex: Arquivamento em sítios externos, Arquivamento em Nuvem, etc**







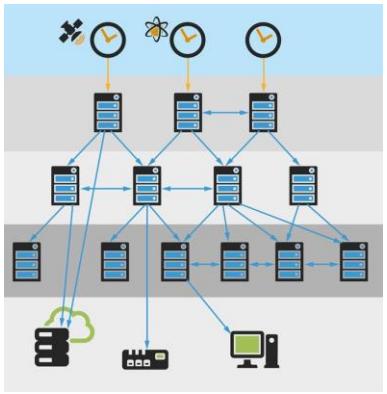




Melhores práticas de segurança da informação

Controles da Norma: Segurança nas Operações

- As atividades dos usuários precisam ser registradas e monitoradas!
  - Registrar e monitorar as atividades dos usuários em todos os sistemas de processamento de informação da organização.
  - Analisar os registros (log) das atividades dos usuários, avaliar todas as falhas registradas e providenciar as ações corretivas em tempo hábil.
  - Proteger os registros (log) contra acesso não autorizado e adulteração.
  - Registrar as atividades dos administradores e operadores do sistema.
  - Manter o sincronismo dos relógios de todos os sistemas de processamento de informações com a mesma fonte de tempo.
    - NTP – Network Time Protocol



Fonte: NTP Zeit.DE Website
URL: https://www.ntp-zeit.de/index-en.htm

Melhores práticas de segurança da informação

Controles da Norma: Segurança nas Operações

- **É importante limitar as ações do usuário no sistema operacional!**
  - **Impedir que os usuários executem atividades as administrativas do sistema operacional.**
  - **Implementar procedimentos para impedir que o usuário faça a instalação ou desinstalação de software nos sistemas operacionais.**
    - **Os sistemas devem fazer a distinção entre usuário privilegiado (administrador do sistema) e usuário limitado (usuário do sistema).**
    - **O usuário limitado deve ser impedido de elevar seus privilégios no sistema operacional.**
    - **As operações administrativas devem ser executadas exclusivamente por administradores do sistema.**
    - **Todos os softwares homologados e necessários para o trabalho do usuário limitado devem estar instalados e disponíveis para uso.**

Melhores práticas de segurança da informação

Controles da Norma: Segurança nas Operações

- **É importante resolver os problemas das vulnerabilidades técnicas!**
  - **Agir em tempo hábil para resolver os problemas pertinentes às vulnerabilidades técnicas para evitar que sejam exploradas por um agente malicioso.**
  - **Buscar constantemente as informações sobre as vulnerabilidades técnicas dos sistemas operacionais e sistemas de processamento informação.**

Common Vulnerabilities and Exposures

  - **Avaliar os riscos associados às vulnerabilidades e traçar um plano de redução dos riscos para evitar danos ou perdas de informação, e/ou interrupção dos sistemas de processamento da informação.**

Melhores práticas de segurança da informação

Controles da Norma: Segurança nas Operações

- **A auditoria dos sistemas de informação não pode parar a organização!**
  - **Auditar os sistemas operacionais e sistemas de processamento da informação minimizando impactos sobre as atividades da organização.**
  - **Garantir a disponibilidade de operação dos sistemas corporativos para os usuários mesmo diante das operações de auditoria.**



Fonte: Auditoria interna e compliance: Quais são as diferenças? - Canal Sinnex Westcon
URL: https://blogbrasil.westcon.com/auditoria-interna-e-compliance-quais-sao-as-diferencas

Melhores práticas de segurança da informação

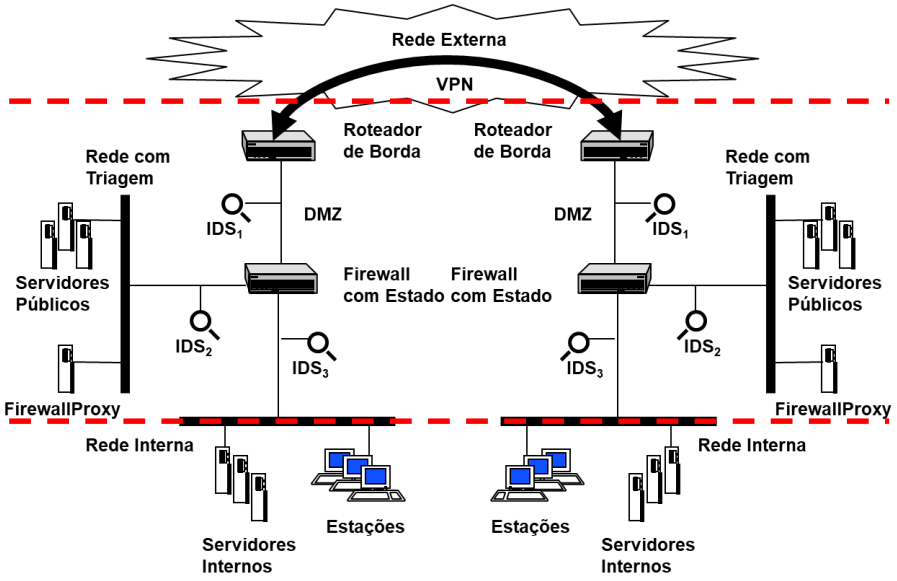
Controles da Norma: Segurança nas Comunicações

- **É fundamental garantir a segurança das redes de dados!**
  - **Garantir a proteção da rede de comunicação de dados e minimizar os riscos de comprometimento da informação ou interrupção dos sistemas de processamento da informação.**
  - **Implantar barreiras de proteção entre as redes internas da organização para proteger contra ataques oriundos da rede interna.**
  - **Implantar barreiras de proteção entre a rede interna e a rede externa para proteger contra ataques oriundos da rede externa.**

Melhores práticas de segurança da informação

Controles da Norma: Segurança nas Comunicações

- **É fundamental garantir a segurança das redes de dados!**
  - **Garantir a proteção da rede de comunicação de dados e minimizar os riscos de comprometimento da informação ou interrupção dos sistemas de processamento da informação.**
  - **Perímetro de segurança de redes.**



Melhores práticas de segurança da informação

Controles da Norma: Segurança nas Comunicações

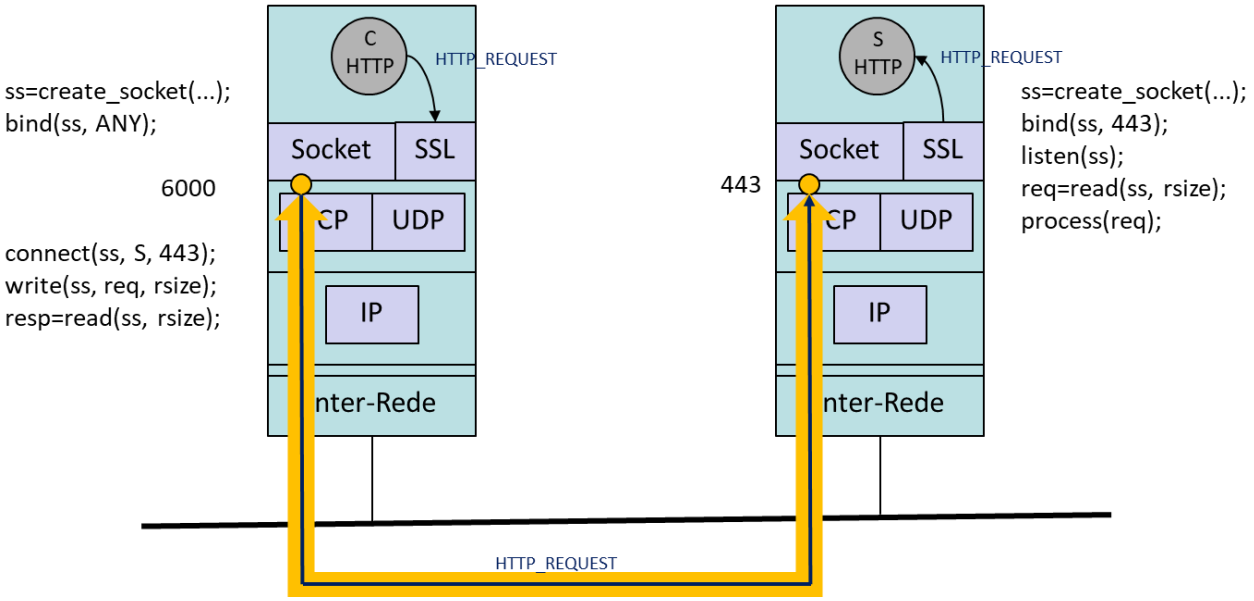
- **É fundamental proteger a informação que transita na redes de dados!**
  - **Garantir a proteção da informação que transita na rede interna da organização e na rede externa oriundas ou destinadas a outras entidades.**
  - **Desenvolver políticas e implantar procedimentos para garantir a comunicação segura entre os interlocutores da comunicação.**
  - **O padrão de comunicação segura varia em função do tipo de comunicação:**
    - **Proteção da carga dos pacotes entre dois pontos:**
      - **TLS (Transport Layer Security)**
    - **Proteção de todo o fluxo de pacotes entre dois pontos:**
      - **VPN (Virtual Private Network)**

Melhores práticas de segurança da informação

Controles da Norma: Segurança nas Comunicações

- **É fundamental proteger a informação que transita na redes de dados!**
  - **Garantir a proteção da informação que transita na rede interna da organização e na rede externa oriundas ou destinadas a outras entidades.**

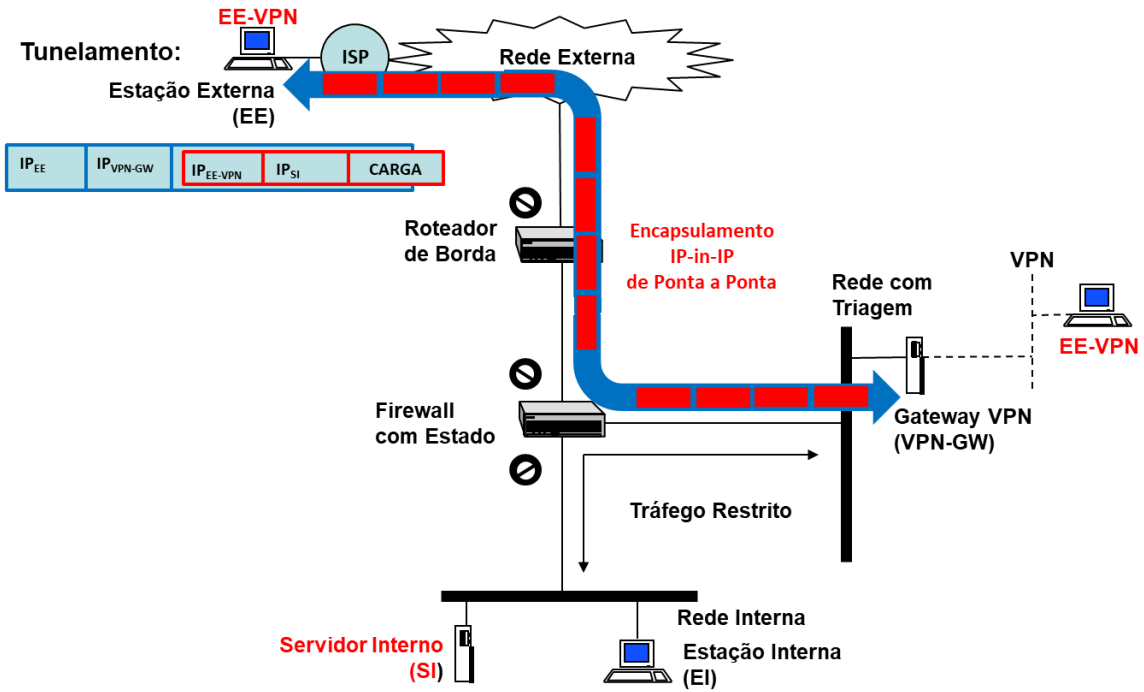
Secure Socket Layer (SSL) e Transport Layer Security (TLS): Exemplo: HTTP over TLS/SSL



Melhores práticas de segurança da informação

Controles da Norma: Segurança nas Comunicações

- **É fundamental proteger a informação que transita na redes de dados!**
  - **Garantir a proteção da informação que transita na rede interna da organização e na rede externa oriundas ou destinadas a outras entidades.**



Melhores práticas de segurança da informação

Controles da Norma: Aquisição, Desenvolvimento e Manutenção de Sistemas de Informação

- **Sempre observar os requisitos de segurança exigidos nos sistemas!**
  - **Garantir que os requisitos de segurança da informação estão atendidos durante todo o ciclo de vida dos sistemas de processamento de informação utilizados internamente e externamente pela organização.**
  - **Determinar os requisitos de segurança da informação que devem ser implantados nos sistemas de processamento de informação.**
  - **Proteger todos os sistemas de processamento de informação contra atividades fraudulentas, disputas contratuais e divulgação ou modificações não autorizadas.**
  - **Garantir a integridade, autenticidade, confidencialidade, controle de acesso e disponibilidade das informações processadas e a irretratabilidade das transações.**

Melhores práticas de segurança da informação

Controles da Norma: Aquisição, Desenvolvimento e Manutenção de Sistemas de Informação

- **Os processos de desenvolvimento dos sistemas devem ser seguros!**
  - **Incorporar a segurança da informação em todas as etapas do desenvolvimento dos sistemas de processamento de informação.**
  - **Aplicar os requisitos de segurança da informação serão aplicados no desenvolvimento dos sistemas de processamento de informação.**
  - **Aplicar os requisitos de segurança da informação quando ocorrerem mudanças nos sistemas de processamento de informação.**
  - **Executar testes para verificar se todos os requisitos de segurança da informação estão adequados para o propósito dos sistemas de processamento de informação.**
  - **Proteger os ambientes de desenvolvimento dos sistemas de processamento de informações.**

Melhores práticas de segurança da informação

Controles da Norma: Aquisição, Desenvolvimento e Manutenção de Sistemas de Informação

- **Os processos de desenvolvimento dos sistemas devem ser seguros!**
  - **Incorporar a segurança da informação em todas as etapas do desenvolvimento dos sistemas de processamento de informação.**
  - **Supervisionar as atividades de desenvolvimento realizadas por colaboradores externos e estabelecer critérios para aceitação dos sistemas desenvolvidos.**
  - **Selecionar com cuidado, proteger e controlar os dados de teste.**
    - **Sempre que possível, os dados utilizados nos testes devem ser dados simulados, ou seja, não devem ser dados reais.**
    - **Quando não for possível, deve-se estabelecer acordos de confidencialidade e não divulgação com os desenvolvedores dos sistemas.**

Melhores práticas de segurança da informação

Controles da Norma: Relacionamento na Cadeia de Suprimento

- **É fundamental exigir segurança da informação na cadeia de suprimento!**
  - **Prover o nível de segurança adequado para os ativos de informação que serão acessados pelos fornecedores.**
  - **Documentar os requisitos de segurança da informação que forem acordados para proteger os ativos de informação que serão acessados, processados ou armazenados pelos fornecedores.**



Melhores práticas de segurança da informação

Controles da Norma: Relacionamento na Cadeia de Suprimento

- **É fundamental exigir segurança da informação na cadeia de suprimento!**
  - **Prover o nível de segurança adequado para os ativos de informação que serão acessados pelos fornecedores.**

  - **Terceirização de serviços de processamento e armazenamento de dados:**
    - **Preferir terceirizados com certificação ISO/IEC 27001 e/ou SAS#70.**
      - **A certificação ISO/IEC 27001 demonstra que o terceirizado utiliza as melhores práticas de segurança da informação e adota um Sistema de Gestão de Segurança da Informação.**
      - **A certificação SAS#70 (atual SSAE 16) demonstra que o terceirizado passou por uma avaliação profunda dos seus objetivos de controle e atividades de controle, que muitas vezes inclui os controles sobre TI e processos relacionados.**

      A certificação SAS#70 é essencial quando o terceirizado opera com informações sensíveis da empresa ou de clientes da empresa, como por exemplo, processamento de folha de pagamento.

DEPARTAMENTO DE INFORMÁTICA PUC-RIO

PUC RIO

Melhores práticas de segurança da informação

Controles da Norma: Relacionamento na Cadeia de Suprimento

- **É fundamental exigir segurança da informação na cadeia de suprimento!**
  - **Prover o nível de segurança adequado para os ativos de informação que serão acessados pelos fornecedores.**
  - **Contratação de serviços de computação em nuvem:**
    - **Seguir à risca as recomendações para a terceirização de serviços de processamento e armazenamento de dados em qualquer uma das modalidades de serviços de nuvem (ex: IaaS, PaaS, SaaS, entre outros).**
    - **Preferir provedores com certificação ISO/IEC 27017 (27002 para serviços de nuvem), 27018 (código de prática para proteção de informações de identificação pessoal (PII) em nuvens públicas) e 27701 (Sistema de Gestão de Informação Privada).**
    - **Ponderar entre solução de nuvem pública ou híbrida (nuvem privada integrada com uma nuvem pública).**

Melhores práticas de segurança da informação

Controles da Norma: Relacionamento na Cadeia de Suprimento

- **É fundamental exigir segurança da informação na cadeia de suprimento!**
  - **Prover o nível de segurança adequado para os ativos de informação que serão acessados pelos fornecedores.**
  - **Contratação de serviços de computação em nuvem**



Fonte: Infraestrutura e Serviços para Cloud: Sobre a Nuvem Híbrida, Sadi, Scurra TI.

Melhores práticas de segurança da informação

Controles da Norma: Relacionamento na Cadeia de Suprimento

- **É fundamental exigir segurança da informação na cadeia de suprimento!**
  - **Prover o nível de segurança adequado para os ativos de informação que serão acessados pelos fornecedores.**
  - **Contratação de serviços de computação em nuvem**
    - **Avaliar os riscos da operação em nuvem do ponto de vista econômico e financeiro para a empresa.**
      - **O investimento inicial em infraestrutura de TI é reduzido;**
      - **O custo do serviço é em função do consumo e pode ser ajustado dinamicamente (*elasticidade*);**
      - **Os serviços em nuvem tarifam processamento de dados, armazenamento de dados e transferência de dados;**
      - **A migração do serviço para outra nuvem ou para o ambiente da empresa pode se tornar inviável do ponto de vista técnico e econômico.**

Melhores práticas de segurança da informação

Controles da Norma: Gestão de Incidentes de Segurança da Informação

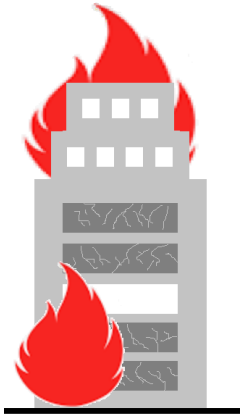


- **É fundamental estar preparado para a gestão de incidentes!**
  - **Garantir o tratamento dos incidentes de segurança da informação e das fragilidades de segurança da informação que forem notificadas.**
  - **Designar responsabilidades e implantar procedimentos para rapidamente tratar dos incidentes de segurança da informação.**
  - **Divulgar os canais apropriados para receber, registrar e tratar os incidentes de forma rápida e efetiva.**
  - **Orientar os funcionários e os colaboradores externos a notificar quaisquer fragilidades de segurança da informação aos canais apropriados.**
  - **Identificar, coletar, adquirir e preservar as informações que podem servir como evidências.**
  - **Aprender com os incidentes de segurança da informação para reduzir a probabilidade ou impacto de incidentes futuros.**

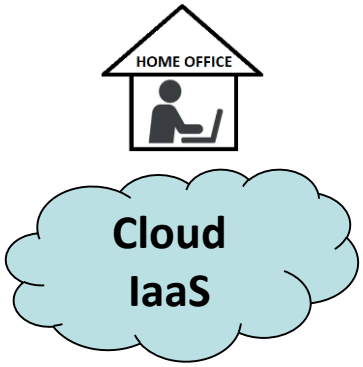
Melhores práticas de segurança da informação

Controles da Norma: Gestão da Continuidade do Negócio

- **É essencial ter um plano de continuidade com segurança da informação!**
  - **Garantir que segurança da informação está incorporada na gestão da continuidade do negócio da organização.**
  - **Determinar os requisitos de segurança da informação que devem ser mantidos durante crises ou desastre para implantar ou aprimorar o plano de continuidade do negócio atendendo tais requisitos.**



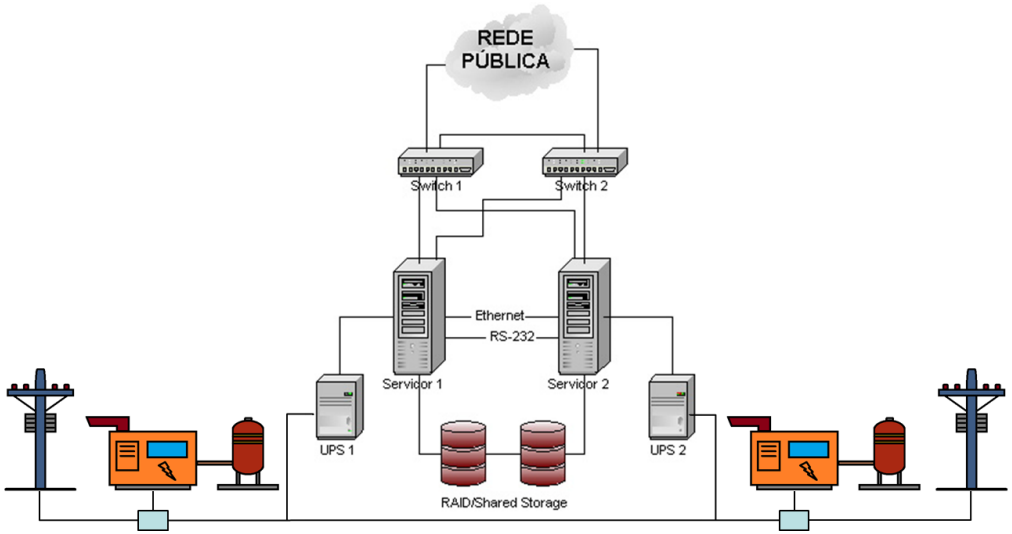
Execução do Plano de Recuperação de Desastre



Melhores práticas de segurança da informação

Controles da Norma: Gestão da Continuidade do Negócio

- **O grau de disponibilidade depende da redundância disponível!**
  - **Garantir a disponibilidade dos sistemas de processamento de informação.**
  - **Identificar os requisitos de disponibilidade dos sistemas de processamento de informação e implantar a redundância necessária para cumprir tais requisitos.**



Melhores práticas de segurança da informação

Controles da Norma: Conformidade

- **É essencial estar em conformidade com os requisitos legais!**
  - **Garantir a adesão da organização a todas as leis, normas, regulamentos e contratos relevantes para segurança da informação.**
  - **Documentar e manter atualizado todo o arcabouço de leis, normas, regulamentos e contratos referentes à segurança da informação relevantes para a organização.**
  - **Implantar a governança para efetivar a conformidade com todo arcabouço de leis, normas, regulamentos e contratos identificados como relevantes para a segurança da informação da organização.**
  - **Dedicar atenção especial para privacidade e proteção das informações de identificação pessoal conforme disposto na LGPD, normas, regulamentos e contratos.**



Melhores práticas de segurança da informação

Controles da Norma: Conformidade

- **É essencial estar em conformidade com os requisitos legais!**
  - **Garantir a adesão da organização a todas as leis, normas, regulamentos e contratos relevantes para segurança da informação.**
  - **Proteger registros importantes contra perda, destruição, falsificação, acesso não autorizado e liberação não autorizada, de acordo com os requisitos regulamentares, estatutários, contratuais e do negócio.**
  - **Determinar que os gestores façam constantemente a análise crítica da conformidade dos procedimentos e do processamento da informação dentro das suas áreas de responsabilidade.**
  - **Analisar criticamente a conformidade dos sistemas de processamento da informação com as normas e políticas de segurança da informação da organização.**

